

CVEs más relevantes de la semana

Del 22/09/2026 al 29/09/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-95848

Descripción: Moquette is a lightweight Java MQTT broker. Prior to 0.18.1, when a configured authenticator or authorizer class cannot be loaded, `Server.initializeAuthenticator` and `Server.initializeAuthorizerPolicy` treat the failure as though no custom class was configured and fall back to `AcceptAllAuthenticator` or `PermitAllAuthorizerPolicy`. A misspelled class name, missing dependency, constructor failu...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-636

Tecnología: No especificado

Publicado el: 2026-09-23



CVE-2026-96755

Descripción: orval versions 8.14.0 through 8.28.1 contain a code injection vulnerability in the @orval/effect generator that converts OpenAPI schema defaults into template literals. Attackers can inject arbitrary JavaScript expressions via schema defaults containing `${...}` syntax, which are executed at module scope when the generated code is built or imported.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-09-23



CVE-2026-97063

Descripción: X-SpringBoot through 6.0 returns login verification codes in HTTP responses from unauthenticated endpoints GET /sys/mobile/code and GET /sys/email/code without sending them to account owners. Attackers can request codes using known mobile numbers or email addresses, read them from responses, and authenticate as victims via POST /sys/emailOrMobileLogin/login to hijack accounts.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-09-25



CVE-2026-97064

Descripción: X-SpringBoot through 6.0 ships with a hardcoded static master login verification code 172839 enabled by default in the database seed. Unauthenticated attackers can authenticate as any user by submitting the public master code to the emailOrMobileLogin endpoint with a known email or mobile number.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-1392

Tecnología: No especificado

Publicado el: 2026-09-25



CVE-2026-100717

Descripción: froxlor is a server administration panel. In versions 2.3.10 and earlier, Validate::validateUrl rejects carriage return and line feed characters only in the path, query and fragment components returned by parse_url, and never inspects the userinfo (user:pass@) components. This is an incomplete fix for GHSA-c3p2. An authenticated low-privilege customer with subdomain-create rights (no admin or c...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:H/A:H

Tipo: CWE-93

Tecnología: No especificado

Publicado el: 2026-09-26



CVE-2026-88771

Descripción: Improper input validation vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway.

This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to an unauthenticated attacker to execute arbitrary commands.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-09-27



CVE-2026-88773

Descripción: Inconsistent interpretation of HTTP requests ('HTTP Request/Response smuggling') vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway.

This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1-37.279 and NDcPP; Gateway: before 14.1-73.37 FIPS and before 13.1-64.23.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-444

Tecnología: No especificado

Publicado el: 2026-09-27



CVE-2026-88775

Descripción: Memory overflow vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway.

This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading Memory overflow vulnerability leading to unpredictable or erroneous behavior or Denial of Service

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-120

Tecnología: No especificado

Publicado el: 2026-09-27



CVE-2026-88776

Descripción: Memory overflow vulnerability vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to unpredictable or erroneous behavior or Denial of Service

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-27



CVE-2026-88777

Descripción: Memory overflow vulnerability vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway.

This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to unpredictable or erroneous behavior or Denial of Service

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-27



CVE-2026-101065

Descripción: Obot is an open-source AI agent/MCP platform. In all versions up to and including commit d7e6970, the Docker quickstart command documented in the README starts the container listening on 0.0.0.0:8080 with authentication disabled by default. When authentication is disabled, every request is mapped to a synthetic "nobody" user that holds the Owner and Admin roles, so any unauthenticated party who...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-09-27



CVE-2026-101084

Descripción: obot versions before v0.21.1 fail to enforce Access Control Rules on the /mcp-connect endpoint, allowing any authenticated user to connect to restricted MCP servers if they possess the server ID. Attackers can bypass authorization checks to access and manipulate sensitive backend systems through MCP tool calls using stored OAuth credentials.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-09-27



CVE-2026-101000

Descripción: A vulnerability was determined in Netcore NBR100V2 1.3.240614.030928. This affects the function uci.apply of the file /usr/share/rpcd/acl.d/unauthenticated.json of the component ACL Handler. This manipulation of the argument section causes missing authorization. It is possible to initiate the attack remotely. The exploit has been publicly disclosed and may be utilized. The vendor was contacted ...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-09-28



CVE-2026-101037

Descripción: A vulnerability was found in FAST FAC1200R 5.0_20201119_1.0.2. Affected is the function `parse_advertisement_frame` of the component `devdiscover Service`. The manipulation results in stack-based buffer overflow. The attack may be launched remotely. The exploit has been made public and could be used. The vendor was contacted early about this disclosure but did not respond in any way.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-28



CVE-2026-101038

Descripción: A vulnerability was determined in FAST FAC1200R 5.0_20201119_1.0.2. Affected by this vulnerability is the function MmtAtePrase of the component MmtAtePrase Parser. This manipulation causes stack-based buffer overflow. Remote exploitation of the attack is possible. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about this disclosure but did not respon...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-28



CVE-2026-101072

Descripción: A vulnerability was identified in Netcore NR289-GE 1.4.5102. This issue affects the function system of the file /ap_ip.cgi of the component CGI Handler. Such manipulation of the argument ip leads to os command injection. The attack can be launched remotely. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but did not respond in any way.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-09-28



CVE-2026-101076

Descripción: A vulnerability was detected in Netcore NR289-GE 1.4.5102. This affects the function system of the file /set_ntp_server_ip.cgi of the component CGI Handler. The manipulation of the argument ntp_ip results in os command injection. The attack can be executed remotely. The exploit is now public and may be used. The vendor was contacted early about this disclosure but did not respond in any way.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-09-28



CVE-2026-101077

Descripción: A flaw has been found in Netcore NR289-GE 1.4.5102. This impacts the function process_request of the component boa_temp Handler. This manipulation causes missing authentication. The attack is possible to be carried out remotely. The exploit has been published and may be used. The vendor was contacted early about this disclosure but did not respond in any way.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-09-28



CVE-2026-101081

Descripción: A security flaw has been discovered in D-Link DI-8400 16.07. This vulnerability affects the function menu_nat_more.asp of the file menu_nat_more.asp of the component Web Administration Service. The manipulation of the argument opt results in stack-based buffer overflow. The attack can be launched remotely. The exploit has been released to the public and may be used for attacks.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-28



CVE-2026-101261

Descripción: A flaw has been found in Ziroom ZHOME A0101 1.0.1.0. This affects an unknown part of the file `/api/ZRnetwork/firstSetup_wifi`. Executing a manipulation of the argument `login_pwd` can lead to command injection. The attack may be performed from remote. The exploit has been published and may be used. The vendor was contacted early about this disclosure but did not respond in any way.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-09-28



CVE-2026-101264

Descripción: A vulnerability was determined in Ziroom ZHOME A0101 1.0.1.0. Impacted is an unknown function of the file /api/ZRnetwork/set_passwd. This manipulation of the argument password1 causes command injection. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about this disclosure but did not respond in any way.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-09-29



CVE-2026-102361

Descripción: mall4j through 4.0 contains a missing authentication vulnerability in the PUT /user/updatePwd endpoint that allows unauthenticated attackers to reset any storefront account password. Attackers can supply a target username in the request body to overwrite passwords without verification, enabling account takeover and access to orders and personal data.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-09-29



CVE-2023-54400

Descripción: Fumasoft Fumeng Cloud contains a SQL injection vulnerability in the AjaxMethod.ashx endpoint that allows unauthenticated remote attackers to inject arbitrary SQL through the Name parameter of the getEmpByname action without any authentication. Attackers can exploit UNION-based SQL injection techniques against the Microsoft SQL Server backend to extract, disclose, and modify database contents, w...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-09-29



CVE-2026-84436

Descripción: IBM Guardium Data Protection 12.2 is vulnerable to command injection in the certificate export CLI functionality, allowing a privileged authenticated CLI user to execute arbitrary commands with root privileges.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-09-29



CVE-2026-53988

Descripción: Dockhand before 1.0.40 contains an authentication bypass vulnerability in its git webhook endpoints that allows unauthenticated remote attackers to trigger arbitrary stack redeployments by exploiting a null webhook secret guard condition. Attackers can enumerate sequential stack IDs and send unsigned webhook requests to force git clone and docker compose operations, enabling denial of service o...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-09-29



Resumen del Reporte

CVEs analizados: 25

Promedio CVSS: 9.63

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

